NIS2 kontrollnimekiri

Artikli 21 lõike 2 punktid (a)–(j) ühes vaates: mida auditeerija tõendina küsib, milline on soovituslik esimene samm ja milline on tüüpiline puudujääk. Juhtorgani kohustused on eraldi osas. Märgi tehtud punktid ja vaata, kus seisad.

Koostanud Arle Aron Reidma, Tehisabiline OÜ · Viimati sisuliselt uuendatud 27. oktoobril 2026

Lühidalt

NIS2 kontrollnimekiri katab direktiivi artikli 21 lõike 2 punktid (a)–(j): kümme meedet, mida direktiiv nimetab vähemalt nõutavaks. Juhtorgani kohustused tulenevad artiklist 20 ja on eraldi osas. Iga meetme juures on kirjas, mida auditeerija tõendina küsib, milline on soovituslik esimene samm ja milline on tüüpiline puudujääk. Nimekiri aitab seisu kaardistada ja tegevuskava järjestada, kuid ei asenda sõltumatut auditit ega hinda meetmete tegelikku toimimist. Punktide sõnastus on sisuline tõlge direktiivi inglisekeelsest tekstist.

Kasuta seda juhatuse või turvajuhi töövahendina: märgi tehtud punktid, vaata edenemist ja vali järgmised sammud. Edenemine salvestub ainult sinu brauseris.

Pole kindel, kas NIS2 üldse kohaldub? Alusta ülevaatest: NIS2 Eestis: ülevaade. Seejärel tee nelja küsimusega enesekontroll. Auditi ulatuse ja aruande kohta vaata NIS2 auditi juhendit.

Riskiregistri töömall: CSV · juhend.

Laadi kontrollnimekiri PDF-ina · Intsidendist teatamise juhend

Auditi tõendite mall (Excel) aitab kirjeldada omaniku, testi ja paranduse. Töövihikus on rida igale punktile (a)–(j) ja juhtorgani kohustustele (art 20).

Kümme meedet

Punktide sõnastus on sisuline tõlge artikli 21 lõike 2 punktidest (a)–(j). Logid on tõend mitme punkti juures, mitte eraldi artikli 21 meede. Soovitused ja näited on märgitud sõnadega „soovitus“ ja „näide“; need ei ole õigusnõuded.

- [ ] **(a) Riskianalüüs ja infosüsteemide turvalisuse poliitika**

  Nõue (art 21 lg 2 p a): dokumenteeritud riskianalüüs ja kinnitatud infosüsteemide turvalisuse poliitika.

  Auditeerija küsib: riskiregistrit koos omanikega, poliitika versiooni ja kinnitamise tõendit ning infovarade loetelu.

  Soovitus: kirjuta üles kümme kriitilisemat infovara ja viis suurimat riski koos vastutajaga. Riskiregistri ülesehitus: küberriskide register.

  Tüüpiline puudujääk (näide): poliitika on olemas, kuid sellel puudub omanik ja regulaarne ülevaatus.

- [ ] **(b) Intsidentide käsitlemine**

  Nõue (art 21 lg 2 p b): intsidentide tuvastamise, käsitlemise, eskaleerimise ja teatamise kord koos rollidega.

  Auditeerija küsib: intsidendiplaani, kontaktide nimekirja, viimase õppuse tulemusi ja teavitamise malli.

  Soovitus: ühelehekülјeline tegevusplaan koos kontaktidega. Ööpäevaringne kontakt on sisemine soovitus, mitte registreerimisnõue. Teatamise tähtajad: intsidendist teatamise juhend.

  Tüüpiline puudujääk (näide): plaan on kirjutatud, kuid seda pole kordagi läbi harjutatud.

☐ **(c) Toimepidevus, varukoopiate haldus ja taastamine ning kriisijuhtimine**

Nõue (art 21 lg 2 p c): toimepidevus, sh varukoopiate haldus ja taastamine, ning kriisijuhtimine.

Auditeerija küsib: varunduse taastetesti logi, taastamisaega (RTO), andmekao piiri (RPO) ja kriisijuhtimise korda.

Soovitus: taasta üks kriitiline süsteem varukoopiast ja mõõda kulunud aega. Vaata varunduse taastetesti juhendit.

Tüüpiline puudujääk (näide): varundus on olemas, kuid taastamist pole kunagi testitud.

☐ **(d) Tarneahela turvalisus**

Nõue (art 21 lg 2 p d): tarneahela turvalisus, sh turvaaspektid suhetes otseste tarnijate ja teenuseosutajatega.

Auditeerija küsib: tarnijate loetelu kriitilisusega, lepingute turvatingimusi ja hindamise märkmeid.

Soovitus: märgi kümme kriitilisemat tarnijat ja nende ligipääsud sinu süsteemidele. Hindamise põhimõtted: NIS2 tarneahela juhend.

Tüüpiline puudujääk (näide): lepingutes puuduvad turvanõuded ja teavitamise kord.

☐ **(e) Turvalisus hankimisel, arendamisel ja hooldamisel**

Nõue (art 21 lg 2 p e): turvalisus võrgu- ja infosüsteemide hankimisel, arendamisel ja hooldamisel, sh haavatavuste käsitlemine ja avalikustamine.

Auditeerija küsib: haavatavuste käsitlemise korda, sõltuvuste skaneerimise aruandeid ja parandamise logi.

Soovitus: lülita sisse sõltuvuste turbeteated. Sisemise sihina määra kriitiliste haavatavuste parandamise tähtaeg, näiteks seitse päeva. See ei ole õigusnõue.

Tüüpiline puudujääk (näide): haavatavusi skaneeritakse, kuid puudub tähtaeg ja vastutaja.

- [ ] **(f) Riskijuhtimismeetmete tõhususe hindamine**

  Nõue (art 21 lg 2 p f): poliitikad ja menetlused, millega hinnatakse küberturvalisuse riskijuhtimismeetmete tõhusust.

  Auditeerija küsib: testiraporteid, paranduste jälgimist ja juhtkonna ülevaatuse märkmeid.

  Soovitus: korralda üks test, näiteks läbistustest, ja seo leiud parandusplaaniga.

  Tüüpiline puudujääk (näide): test on tehtud, kuid leiud jäävad jälgimata.

- [ ] **(g) Küberhügieen ja küberturvalisuse koolitus**

  Nõue (art 21 lg 2 p g): elementaarsed küberhügieenitavad ja küberturvalisuse koolitus.

  Auditeerija küsib: koolituskava, osalejate nimekirja, materjale ja õppuste tulemusi.

  Soovitus (näide, sisemine siht): 30-minutiline koolitus ja üks andmepüügi test. NIS2 ei sätesta koolituse pikkust ega sagedust.

  Tüüpiline puudujääk (näide): koolitus on tehtud üks kord töölevõtmisel.

- [ ] **(h) Krüptograafia ja krüpteerimine**

  Nõue (art 21 lg 2 p h): krüptograafia ja vajaduse korral krüpteerimise kasutamise poliitika ja menetlused.

  Auditeerija küsib: krüpteerimise poliitikat, TLS-i seadistust, võtmete loetelu ja sertifikaatide aegumise jälgimist.

  Soovitus: koosta sertifikaatide ja saladuste loetelu koos aegumiskuupäevadega.

  Tüüpiline puudujääk (näide): võtmed ja paroolid on koodirepos või jagatud tabelis.

- [ ] **(i) Personaliturvalisus, juurdepääsukontroll ja varahaldus**

  Nõue (art 21 lg 2 p i): personaliturvalisus, juurdepääsukontrolli poliitikad ja varahaldus.

  Auditeerija küsib: õiguste maatriksit ja ülevaatuse tõendit, töölt lahkumise protseduuri ning varanimekirja.

  Soovitus: alusta halduskontodest: kontrolli õigusi, kõrvalda jagatud kontod ja kontrolli, et lahkunud töötajate ligipääsud on suletud.

  Tüüpiline puudujääk (näide): jagatud admin-kontod ja endiste töötajate ligipääsud.

- [ ] **(j) Mitmefaktorautentimine ja turvaline side (sh hädaolukorra side)**

  Nõue (art 21 lg 2 p j): mitmefaktorautentimine või pidev autentimine, turvaline hääl-, video- ja tekstside ning turvaline hädaolukorra sidesüsteem üksuse sees, kus see on asjakohane.

  Auditeerija küsib: MFA katvuse loendit kriitiliste kontode kohta, turvalise side kirjeldust ja hädaolukorra sideviisi.

  Soovitus: kehtesta MFA e-postile, halduskontodele ja pilveteenustele. Määra hädaolukorra sideviis, mis töötab ka siis, kui põhisüsteem ei tööta. Vaata MFA juurutamise juhendit.

  Tüüpiline puudujääk (näide): MFA on ainult osadel kontodel ja hädaolukorra side on lahendamata.

Juhtorgani kohustused (art 20 / KüTS § 6^1)

Nõue (art 20): juhtorgan kiidab heaks küberturvalisuse riskijuhtimismeetmed, jälgib nende rakendamist ja vastutab nende eest. Juhatuse liikmed järgivad koolitusi, et mõista riske ja riskijuhtimise viise. KüTS § 6^1 lõike 1 järgi kiidab juhatuse liige heaks turvameetmed, jälgib nende rakendamist ja vastutab selle eest; lõike 2 järgi läbib ta korrapäraselt koolitusi. Direktiiv ei sätesta koolituse sagedust.

Auditeerija küsib: juhatuse protokolli, mis kinnitab riskijuhtimismeetmed, koolituse tõendit juhatuse liikmetelt ja ülevaadet, kuidas juhatus meetmete täitmist jälgib.

Soovitus: lisa küberturvalisus juhatuse päevakorda püsiva punktina ja fikseeri otsused protokollis. Juhatuse kohustuste juhend annab näidispäevakorra.

Tüüpiline puudujääk (näide): vastutus on delegeeritud ilma järelevalve ja aruandluseta.

Tulemuse lugemine (näide)

Kontrollnimekirja tulemus on enesehinnang, mitte audit. Kasuta seda vestluse alusena juhatuses ja tegevuskava järjestamiseks. Allolev skaala on sisemine näide, mitte õiguslik hinnang.

- **0–3 tehtud:** alusta kolmest soovitusest: varunduse taastetest (c), MFA (j) ja ligipääsude ülevaade (i). Need on praktilised esimesed sammud.
- **4–7 tehtud:** põhi on paigas; järgmiseks kinnita tõendid, korralda üks test ja pane paika intsidendist teatamise protsess.
- **8–10 tehtud:** baas on tugev; kontrolli, et tõendid on ajakohased ja meetmeid on päriselt testitud, mitte ainult kirja pandud.

Ükski skoor ei asenda sõltumatut auditit ega tõenda vastavust. Kui tahad välise pilguga kontrolli, vaata küberauditi ulatust.

Teavitamine: 24 tundi, 72 tundi ja üks kuu

Kui olulise mõjuga küberintsident toimub, teatatakse sellest Riigi Infosüsteemi Ametile (RIA) kolmes etapis. Esmane teade ja intsidenditeade loevad alates intsidendist teadasaamisest; lõpparuande tähtaeg loetakse intsidenditeate esitamisest. Kontrollitud 27.10.2026 KüTS kehtiva redaktsiooni järgi (§ 8):

- **Esmane teade:** viivitamata, kuid hiljemalt 24 tunni jooksul (§ 8 lg 1).
- **Intsidenditeade:** viivitamata, kuid hiljemalt 72 tunni jooksul (§ 8 lg 4^1). Usaldusteenuse osutaja esitab intsidenditeate hiljemalt 24 tunni jooksul (§ 8 lg 4^2).
- **Lõpparuanne:** ühe kuu jooksul pärast 72-tunnise intsidenditeate esitamist (§ 8 lg 7). Kui intsident on lõpparuande ajaks veel lahendamata, loetakse esitatud lõpparuanne vahearuandeks ja uus lõpparuanne tuleb ühe kuu jooksul pärast lahendamist. RIA võib nõuda vahearuannet ka varem (§ 8 lg 4^3).

Täpne sisu ja vorm on kirjas intsidendist teatamise juhendis. Isikuandmete rikkumise korral (GDPR art 33) teavitab vastutav töötleja Andmekaitse Inspektsiooni (AKI (https://www.aki.ee/)) 72 tunni jooksul, kui rikkumine tõenäoliselt ohustab füüsiliste isikute õigusi ja vabadusi. Kui ohtu ei ole tõenäoline, teavitamist ei nõuta. Volitatud töötleja teavitab vastutavat töötlejat viivitamata. Need kohustused hinnatakse eraldi.

Tõendid, mida auditeerija küsib

Meede	Peamine tõend	Kes hoiab
(a) Riskianalüüs	Riskiregister, poliitika ja kinnitamise minut	Juhtkond / turvajuht
(b) Intsidendid	Plaan, kontaktid, õppuse ja teavitamise tõendid	IT / turvajuht
(c) Toimepidevus	Taastetesti logi, RTO ja RPO, kriisijuhtimise kord	IT
(d) Tarneahel	Tarnijate loetelu ja lepingutingimused	Hanked / juhtkond
(e) Arendus	Sõltuvuste skaneeringud ja parandustähtajad	Arendus
(f) Tõhususe hindamine	Testiraportid ja paranduste jälgimine	Turvajuht
(g) Küberhügieen ja koolitus	Koolituskava, osalejate nimekiri ja õppuste tulemused	Personal / turvajuht
(h) Krüptograafia	Võtmete loetelu ja sertifikaatide jälgimine	IT
(i) Personal ja ligipääs	Õiguste maatriks ja ülevaatus, töölt lahkumise kord, varanimekiri	IT / personal
(j) MFA ja turvaline side	MFA katvus kriitiliste kontodega, turvalise side ja hädaolukorra sideviisi kirjeldus	IT
Juhtorgani kohustused (art 20)	Juhatuse protokoll, mis kinnitab meetmed; koolituse tõend	Juhatus

Tõend peab olema jälgitav: kes, millal, mis alusel ja mis tulemus. Ekraanitõmmis ilma selgituseta ei ole tavaliselt piisav. Logid on tõend mitme punkti juures (näiteks b, f ja i), mitte eraldi meede.

Küsimused kontrollnimekirja kohta

Mis on NIS2 kontrollnimekiri?

See on läbivaatus artikli 21 lõike 2 punktide (a)–(j) kohta: iga meetme juures on kirjas, mida auditeerija tõendina küsib, milline on soovituslik esimene samm ja milline on tüüpiline puudujääk. Juhtorgani kohustused (art 20) on eraldi osas.

Kas kontrollnimekiri asendab auditit?

Ei. Kontrollnimekiri aitab seisu kaardistada ja tegevuskava järjestada, kuid ei hinda meetmete tegelikku toimimist ega asenda sõltumatut auditit.

Kellele kontrollnimekiri mõeldud on?

Eelkõige NIS2 kohustuslastele ja nende juhtidele, kes peavad meetmete seisu kinnitama, ning ettevõtetele, kes soovivad esmase turvahügieeni üle vaadata.

Kas märkeruutude edenemine salvestatakse kuskile?

Ei. Edenemine salvestub ainult sinu brauseri lokaalsesse mällu ja ei saadeta serverisse. Saad selle igal ajal nullida.

Kust alustada, kui aega on vähe?

Soovitus: alusta varunduse taastetestist (c), mitmefaktorilisest autentimisest (j) ja ligipääsude ülevaatamisest (i). Need on praktilised esimesed sammud, mitte NIS2 järjekord.